

Identity, Access & Provisioning Policy

Document ID: IT-IAM-001 | Effective: June 27, 2026 | Version: 1.0 | Classification: Internal

APPROVED — ACTIVE

1. Purpose & Scope

This policy governs user authentication, role-based access control, account lifecycle management, and privileged access for all systems within the TechCorp Enterprise AI Platform and its connected services. It ensures that every identity accessing TechCorp systems is authenticated, authorized, and auditable, with access granted on a least-privilege basis and revoked promptly when no longer needed.

This policy applies to all employees, contractors, third-party partners, and service accounts accessing the Enterprise AI Platform or any business system integrated with it. It is enforced by the **IT Department** in coordination with the **Security Department** and audited against the access matrices maintained by each department's leadership.

2. AI Platform Integration

The IT Department manages identity and access through a centralized identity provider integrated with the Enterprise AI Platform, with AI-assisted access review and anomaly detection coordinated with the **Security Department**. Core IAM integrations include:

- AI-Powered Access Review Engine** — The platform analyzes access patterns across all departments, flagging unused permissions, privilege creep, and anomalous access attempts for quarterly review by IT administrators and the owning department manager.
- Automated Provisioning & Deprovisioning Pipeline** — Integration with the **HR Department**'s HRIS triggers automatic account creation on hire, role-change updates on promotion or transfer, and account revocation within 24 hours of termination, with AI reconciliation against the access matrix.
- Privileged Access Workbench** — Just-in-time elevated access with AI-assisted session recording and anomaly detection; all privileged sessions are logged, with suspicious command sequences flagged to **Security** in real time.

- **Federated Identity Gateway** — Single sign-on across all platform services and integrated third-party tools, with adaptive multi-factor authentication triggered by AI risk scoring based on location, device, and behavior patterns.

Connected Departments: Security (access monitoring & audit enforcement) • HR (identity lifecycle triggers & role alignment) • Engineering (service account governance & API key management) • AI (access pattern analysis & anomaly model accuracy) • Legal (access audit trail compliance & data access regulation)

3. Permitted Identity & Access Activities

Activity	AI Role	Human Oversight Required
User account provisioning & deprovisioning	HRIS-driven automation & reconciliation	IT administrator reviews monthly reconciliation reports
Role-based access assignment	Role recommendation based on peer analysis	Department manager approves all access grants; quarterly recertification required
Privileged access elevation	Just-in-time workflow & session monitoring	IT admin approves each elevation request; Security reviews flagged sessions
Access review & recertification	Unused-access detection & privilege-creep flagging	Department manager certifies or revokes each flagged access right
Multi-factor authentication enforcement	Risk-based adaptive MFA triggering	Security reviews MFA bypass requests within 24 hours
Service account lifecycle management	Credential rotation scheduling & usage monitoring	Service owner rotates credentials per schedule; IT validates compliance

4. Prohibited Activities

The following are strictly prohibited under this policy:

- **Shared accounts or credential sharing.** Every identity must be uniquely attributable to an individual or an approved service. Shared credentials are prohibited without a formal exception approved by IT and Security for documented operational necessity.
- **Standing privileged access.** Privileged roles must be accessed through just-in-time elevation, not permanently assigned. Standing admin access outside the IT and Security break-glass accounts is prohibited.

- **Bypassing the identity provider for authentication.** All platform services and integrated applications must authenticate through the centralized identity provider. Local authentication silos are prohibited unless explicitly approved by IT and Security.
- **Retaining accounts beyond the access lifecycle.** Accounts inactive for 90 days must be automatically disabled. Accounts not recertified within a review cycle must be suspended. Deprovisioning must complete within 24 hours of termination notification from HR.
- **Unapproved API key or service account creation.** All service accounts and API keys must be registered in the identity provider, governed by a named owner, and subject to the same lifecycle and rotation policies as user accounts.

5. Access Tiers & Authentication Standards

All identity and access controls must comply with TechCorp's **AI Safety Guidelines** (AI Department) and the **Data Protection Standards** (Security Department). Access tiers include:

- Standard access requires password authentication with MFA and is sufficient for general platform use within a department's approved data scope.
- Elevated access requires adaptive MFA with a phishing-resistant second factor and applies to personnel who modify platform configuration, access Confidential data, or manage user accounts for their department.
- Privileged access requires just-in-time request with business justification, manager approval, full session recording, and applies to system administration, security configuration changes, and access to Restricted data.
- All access assignments must align with the department-maintained access matrix reviewed quarterly; deviations require a temporary exception documented in the access governance module and approved by the department head and IT.
- Service accounts must use certificate-based authentication or managed identities where supported; static credentials must rotate every 90 days and are monitored by the AI credential hygiene engine.

6. Access Governance & Quality Standards

IT personnel configuring identity and access systems must adhere to TechCorp's **Prompt Engineering Standards**. IAM-specific requirements include:

- Access review prompts must include the user's role, department, data classification scope, and last 90 days of actual access patterns for meaningful recertification decisions.
- AI-generated access anomaly alerts must include the user identity, resource accessed, normal baseline behavior, and deviation magnitude for efficient Security

triage.

- Role definition prompts for new departments or functions must reference the department's AI policy access requirements and data classification tiers to build accurate permission sets.
- All IAM automation runbooks must be version-controlled and tested during quarterly access audit exercises; AI-generated runbook modifications must be approved by the IAM lead before deployment.

7. Roles & Responsibilities

Role	Responsibility
VP of IT	Overall IAM ownership; identity infrastructure budget; approval of identity provider changes; escalation point for access-related incidents.
IAM Administrator	Day-to-day identity and access operations; provisioning and deprovisioning execution; access review scheduling and enforcement; MFA policy administration.
Department Managers	Access approval for team members; quarterly access recertification; role definition maintenance; notification of role changes and terminations to IT and HR.
Security Department	Access monitoring and anomaly investigation; quarterly access audits; privileged session review; identity threat detection; break-glass account oversight.
HR Department	Identity lifecycle triggers (hire, transfer, termination); role and reporting-line data accuracy in HRIS; coordination with IT for automated provisioning.
Engineering Department	Service account governance; API key lifecycle management; application-level authorization within services; SSO integration for all engineering tools.
AI Department	Access pattern analysis model accuracy; anomaly detection threshold tuning; AI-driven access review tool performance; identity-related prompt standards.
Legal Department	Access audit trail compliance; regulatory access requirements interpretation; data access legal hold coordination with IT.

8. Incident Response

Any of the following constitutes an identity or access incident and must be reported within the timeframe specified:

- Suspected credential compromise or unauthorized access — report within 15 minutes to Security and IT; affected accounts disabled immediately; forced password reset and session invalidation executed.

- Privileged access abuse or anomalous privileged session — Security receives real-time AI alert; IT revokes access within 15 minutes; forensic review of session recording within 24 hours.
- Deprovisioning failure resulting in a terminated employee retaining access — report within 1 hour to IT, Security, and HR; access revoked immediately; root-cause analysis of the deprovisioning pipeline within 48 hours.
- Access review failure where uncertified accounts remain active beyond the review deadline — report within 24 hours to IT and the affected department head; accounts suspended until recertified.
- Identity provider outage affecting authentication — IT detects within 2 minutes; break-glass local authentication activated; all departments notified within 15 minutes; full service restoration within 30 minutes.

All identity incidents are logged in the platform's incident management module. Incidents involving privileged access or credential compromise require a post-incident review within 5 business days involving IT, Security, and the affected department. Material incidents are escalated to the General Counsel and board per the breach notification policy.

9. Training & Compliance

- All IT personnel must complete the Identity & Access Management certification within 60 days of onboarding and recertify annually.
- Department managers must complete the Access Governance & Recertification training before receiving access approval authority and refresh every 12 months.
- All employees must complete the annual Security Awareness training covering password hygiene, MFA usage, and phishing recognition, administered through the Enterprise AI Platform and tracked by HR.
- Quarterly access audits are conducted by IT and Security; findings are reviewed with department heads and tracked to remediation in the access governance module.
- Non-compliance with this policy, including failure to recertify access or sharing credentials, is subject to progressive discipline administered by HR.

10. Review & Revision

This policy is reviewed every 6 months by the VP of IT, IAM Administrator, and Security Department representative, with input from the HR Department (for identity lifecycle integration), Engineering Department (for service account and API governance), AI Department (for access anomaly detection accuracy), and Legal Department (for regulatory access compliance). Revisions are versioned, approved by the VP of IT, and synchronized with updates to the Data Protection Standards, the

Enterprise AI Platform Operations Policy, and the HR employee lifecycle policies. Emergency revisions triggered by identity-related security incidents follow an accelerated 14-day review cycle.

Referenced Policies: Enterprise AI Platform Operations Policy (IT-OPS-001) • Data Protection Standards (Security Department) • AI Safety Guidelines (AI Department) • Prompt Engineering Standards (AI Department) • Employee Handbook & Lifecycle Policies (HR Department) • Legal Department AI Usage Policy (LEG-AI-001)